

Plan de Data Governance — Spotify

Diagnostic de maturité · Politique de gouvernance · Organisation & rôles · Plan d'implémentation et pilote

Emeline ROBLOT — Data Governance Specialist

Septembre 2026 · Version 1.0

Rôle joué	Livrable	Périmètre	Conformités visées
Data Governance Specialist, Spotify	Plan de gouvernance (document unique) et présentation executive associée	Opérations data globales — 450 M d'utilisateurs, 200 M d'abonnés premium, 180+ pays	GDPR · CCPA/CPRA · PCI-DSS · PDPA · LGPD · DSA

Ce document rassemble les quatre étapes du projet en un plan de gouvernance unique. Chaque partie est lisible seule ; les annexes contiennent la checklist de conformité remplie et les sources. Les chiffres sourcés et les hypothèses de travail sont distingués explicitement (annexe B).

Sommaire

Synthèse exécutive	3
Partie 1 — Data Maturity Assessment.....	4
1. Verdict global : 3,4 / 5 — « Proactive » incomplet	4
2. Évaluation par dimension	4
3. Challenges prioritaires	5
4. Cibles à 12 mois	5
Partie 2 — Data Governance Policy	6
1. Objet et champ d’application	6
2. Principes (Governance Principles Guide)	6
3. Qualité des données	6
4. Sécurité, classification, accès et cycle de vie	6
5. Conformité réglementaire	7
6. Rôles et responsabilités	8
7. Application, exceptions et suivi	8
Partie 3 — Organisation & rôles	9
Partie 4 — Implementation Plan & pilote.....	10
1. Modèle organisationnel : Centre of Excellence (CoE).....	10
2. Stack technologique.....	10
3. Plan en 4 phases (18 mois)	10
4. Pilote User Data (Pilot Implementation Template)	11
5. Ressources et budget (ordres de grandeur, hypothèses à affiner en phase 1)	12
6. KPIs de suivi du programme	12
Annexe A — Compliance Checklist (GDPR · CCPA/CPRA · PCI-DSS)	13
Annexe B — Sources et hypothèses	15

Synthèse exécutive

Le constat. Spotify est un leader technologique — architecture et analytics au niveau 5 sur 5 — sans gouvernance transverse des données : pas de Chief Data Officer, pas d'ownership par domaine, des définitions de métriques qui divergent entre Marketing, Product, Engineering et Content. Score de maturité global : **3,4 / 5**, avec la dimension Data Governance à **2**. Le risque n'est pas théorique : en juin 2023, l'autorité suédoise (IMY) a sanctionné Spotify de **58 M SEK** (**≈ 5 M€**) pour un droit d'accès GDPR insuffisamment clair — une défaillance de gouvernance, pas d'infrastructure. L'exposition maximale GDPR représente 4 % du CA mondial, soit **≈ 530 M€** sur le CA 2023.

Le framework. Une Data Governance Policy de trois pages fondée sur les neuf principes du Governance Principles Guide, structurée en trois piliers : qualité et accessibilité (cinq domaines de données, un Data Steward chacun, quatre critères mesurés, un catalogue unique) ; conformité et sécurité (base légale documentée par finalité, sept droits des personnes couverts, DPIA, classification en quatre niveaux, durées de conservation) ; culture et éthique (formation par rôle, audit trimestriel des biais de recommandation, interdiction de profiler sur des catégories sensibles inférées).

L'organisation. Un **Centre of Excellence** sous le CDO, avec cinq Data Stewards relais dans les business units, un DPO indépendant et sa Privacy Team, et un Data Governance Committee mensuel. La gouvernance définit et audite ; l'engineering, sous le CTO, implémente.

Le plan. Quatre phases sur 18 mois : fondations (M1-M2), **pilote User Data sur les marchés UE (M3-M6)** avec Go/No-Go du Committee, généralisation aux quatre autres domaines (M7-M12), industrialisation (M13-M18). Un outil par besoin, en s'appuyant sur l'existant (GCP, Airflow, catalogue Lexikon). Cible de maturité à 12 mois : **4,2 / 5**.

L'impact. Programme estimé à **6-7 M€ sur 18 mois** (ordres de grandeur, hypothèses à affiner en phase 1), soit environ 1 % de l'exposition maximale et à peine plus que la sanction déjà subie ; gains d'efficacité estimés à **≈ 3 M€/an** sur le seul accès aux données. **Trois décisions demandées au comité exécutif** : nommer le CDO sous 30 jours, approuver le budget des phases 1-2 (**≈ 2,5 M€**), lancer la communication interne en M1.

Partie 1 — Data Maturity Assessment

Périmètre : opérations data globales de Spotify (450 M d'utilisateurs actifs, 200 M d'abonnés premium, 180+ pays).

Méthode : Data Maturity Assessment Template (9 dimensions, échelle 1-5) + analyse du business case.

Hypothèses de travail. Ce rapport est réalisé sans accès aux données internes de Spotify. Les éléments suivants sont des hypothèses fondées sur des sources publiques (blog Spotify Engineering, rapports annuels, décision IMY 2023) et devront être validés en phase 1 du plan d'implémentation : infrastructure GCP/BigQuery (migration publique depuis 2016), catalogue interne Lexikon, existence d'un DPO, délégation des paiements à un prestataire certifié PCI-DSS, part de métadonnées de contenu incomplètes.

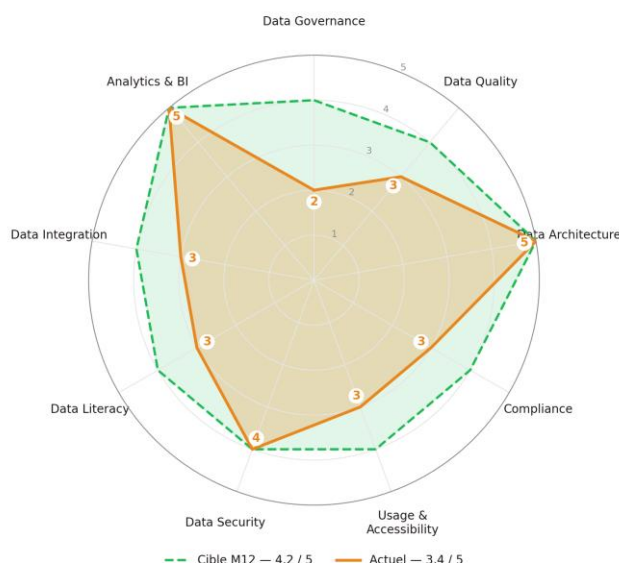
1. Verdict global : 3,4 / 5 — « Proactive » incomplet

Sur l'échelle du cours (Aware → Reactive → Managed → **Proactive** → Effective), Spotify se situe entre **Managed** et **Proactive** : les processus data existent et l'infrastructure est de niveau « Effective », mais la gouvernance formelle, la conformité multi-juridictions et la data literacy hors équipes techniques restent en retrait. La moyenne des 9 dimensions est de **3,4 / 5**.

Le signal le plus concret : en juin 2023, l'autorité suédoise (IMY) a sanctionné Spotify de **58 M SEK (≈ 5 M€)** pour un droit d'accès GDPR insuffisamment clair — une défaillance de gouvernance (information sur les durées de conservation et les transferts), pas d'infrastructure.

2. Évaluation par dimension

Dimension	Actuel	Cible M12	Forces	Faiblesses	Plan d'action
Data Governance	2	4	Besoin identifié, DPO en place (hyp.)	Pas de CDO ni d'équipe transverse ; chaque département gère ses datasets (business case) ; définitions de métriques divergentes	Nommer un CDO, créer un Centre of Excellence, désigner 5 Data Stewards
Data Quality	3	4	Validation sur les pipelines critiques (recommandation)	Métadonnées de contenu incomplètes côté labels/distributeurs indépendants (hyp.) ; pas de métriques qualité partagées	Déployer Great Expectations, 4 critères qualité par domaine, baseline mesurée
Data Architecture	5	5	GCP/BigQuery, data lakes, traitement temps réel	Systèmes hérités des acquisitions podcast (Anchor, Gimlet, Parcast)	Standardiser les pipelines des acquisitions
Compliance	3	4	DPO, politiques de base, réponse aux demandes utilisateurs	Sanction IMY 2023 (droit d'accès) ; pas de DPIA systématique ; effacement non automatisé ; PDPA/LGPD non formalisés	DPIA obligatoires, pipeline d'effacement < 30 j, OneTrust multi-juridictions
Data Usage & Accessibility	3	4	Culture A/B testing, catalogue Lexikon (adoption 95 % des data scientists)	Silos Marketing / Product / Engineering / Content ; pas de vision unifiée du parcours utilisateur	Étendre le catalogue à tous les domaines, règles d'accès par classification
Data Security	4	4	Chiffrement en transit, contrôle d'accès, paiements délégués (PCI-DSS)	Classification des données sensibles incomplète ; pas de SIEM unifié (hyp.)	Classification 4 niveaux, SIEM Splunk
Data Literacy	3	4	Forte dans les squads produit et data	Faible maîtrise des principes de gouvernance et conformité en Marketing, Legal, Content	Formation par rôle, e-learning obligatoire
Data Integration	3	4	Pipelines inter-systèmes opérationnels	Intégration incomplète des podcasts ; pas de lineage de bout en bout	OpenLineage + Marquez, pipelines standardisés
Analytics & BI	5	5	Moteur de recommandation ML de référence (Discover Weekly, Daily Mix), A/B testing massif	Biais et explicabilité des recommandations non audités (obligation DSA art. 27)	Audit trimestriel des biais, explicabilité utilisateur



3. Challenges prioritaires

1. Gouvernance sans structure — URGENT. Pas de CDO, pas d'ownership transverse : les décisions data sont prises département par département. Symptôme : « utilisateur actif » n'a pas la même définition en Marketing et en Product. Le business case le formule ainsi : « *different departments manage their own datasets independently* ».

2. Conformité multi-juridictions — URGENT. Exposition simultanée au GDPR (jusqu'à 20 M€ ou **4 % du CA mondial**, soit ≈ 530 M€ sur un CA 2023 de 13,25 Md€ ; notification de violation sous 72 h), au CCPA/CPRA, au PDPA (Singapour), à la LGPD (Brésil) et au DSA (transparence des recommandations). La sanction IMY 2023 montre que le risque n'est pas théorique.

3. Silos inter-départements — HAUTE. Marketing, Product, Engineering et Content gèrent des datasets séparés. Reconstituer le parcours découverte → conversion premium exige de croiser des données aujourd'hui inaccessibles. Conséquences : analyses incomplètes, doublons, features retardées.

4. Qualité des données — HAUTE. Métadonnées de contenu incomplètes ou erronées (ISRC, droits, genres) et données comportementales capturées de façon inconsistante dégradent la recommandation, la distribution des royalties et le reporting. Face à Apple Music, Amazon Music et YouTube Music, la qualité de la recommandation est un facteur direct de rétention.

5. Privacy et éthique algorithmique — HAUTE. Les utilisateurs et régulateurs attendent transparence, anonymisation quand c'est possible et contrôle sur les données (opt-out, effacement). Les historiques d'écoute peuvent révéler des informations sensibles inférées (humeur, convictions) et la recommandation n'est pas auditée pour les biais.

4. Cibles à 12 mois

Priorités : **urgente** pour Data Governance (2 → 4) et Compliance (3 → 4) ; **haute** pour Data Quality, Usage & Accessibility et Data Literacy (3 → 4) ; **moyenne** pour Data Integration ; **maintenir** Architecture, Security et Analytics (avec audit des biais).

Score cible : 4,2 / 5 (niveau « Proactive » consolidé). Les trois dimensions les plus urgentes — Governance, Compliance, Data Quality — structurent le framework (document de politique) et le plan d'implémentation.

Partie 2 — Data Governance Policy

Owner	Approbation	Version	Date d'effet	Revue
Chief Data Officer	Data Governance Committee, avis DPO et Legal	1.0	M1 du plan d'implémentation	Annuelle, ou à tout changement réglementaire majeur

1. Objet et champ d'application

Objet. Cette politique définit comment Spotify gouverne ses données pour atteindre les quatre objectifs du business case : qualité des données, conformité réglementaire (GDPR, CCPA/CPRA, PCI-DSS, réglementations locales), protection de la vie privée, accessibilité et intégration des données entre départements.

Champ d'application. Elle s'applique à tous les employés, prestataires et systèmes qui collectent, stockent, traitent ou partagent des données Spotify, dans les 180+ pays d'opération. Elle couvre les cinq domaines de données et leurs owners :

Domaine	Données	Data Steward	Criticité
User Data	Profils, historiques d'écoute, recherches, playlists, localisation	Steward User	Très haute — GDPR, recommandation
Content	Métadonnées musicales et podcasts (ISRC, artistes, droits)	Steward Content	Haute — recommandation, royalties
Payments	Abonnements, transactions, facturation	Steward Payments	Très haute — PCI-DSS
Ads	Campagnes, ciblage, impressions, segments	Steward Ads	Haute — opt-out CCPA
Marketing	Engagement, segmentation, conversion free → premium	Steward Marketing	Haute — croissance

Définitions. *Donnée personnelle* : toute information relative à une personne identifiable (GDPR art. 4). *Donnée sensible* : catégories de l'art. 9 GDPR, y compris les informations **inférées** (humeur, convictions, santé déduites des écoutes). *Data Owner* : responsable métier d'un domaine. *Data Steward* : garant opérationnel de la qualité et de la conformité d'un domaine. *Traitement* : toute opération sur des données personnelles.

2. Principes (Governance Principles Guide)

#	Principe	Engagement Spotify
1	Accountability	Un owner et un steward nommés par domaine ; RACI publié
2	Transparency	Privacy notice claire par finalité ; consentement granulaire ; information sur durées de conservation et transferts (point sanctionné par l'IMY en 2023)
3	Data Security	Chiffrement, contrôle d'accès par rôle, SIEM, protocole d'incident
4	Data Quality	4 critères mesurés par domaine, audits réguliers
5	Compliance	Revue trimestrielle ; checklist GDPR/CCPA/PCI-DSS tenue à jour (annexe)
6	Data Minimization	Collecte limitée à la finalité ; revue annuelle des datasets et durées de conservation
7	User Rights	Exercice des droits en libre-service et via la Privacy Team, dans les délais légaux
8	Continuous Improvement	Revue annuelle de la politique, retours du Committee et des équipes
9	Ethical Use	Audit des biais de recommandation, explicabilité, pas de profilage sur catégories sensibles inférées

3. Qualité des données

Chaque domaine mesure quatre critères, avec une baseline établie avant toute cible :

Critère	Définition	Cible	Mesure
Complétude	Champs obligatoires renseignés	> 98 %	Great Expectations dans les pipelines
Exactitude	Conformité aux formats et référentiels (ex. ISRC valide)	> 99 %	Great Expectations
Cohérence	Une seule définition par métrique (glossaire métier)	100 % des métriques du glossaire	Catalogue de données
Fraîcheur	Délai production → disponibilité	< 1 h pour les flux temps réel	Observabilité (phase 4)

Les Data Stewards publient les scores mensuellement au Data Governance Committee. Un dataset critique sous la cible deux mois de suite déclenche un plan de remédiation.

4. Sécurité, classification, accès et cycle de vie

Classification (obligatoire pour tout dataset catalogué) :

Classe	Exemples	Protection minimale
Publique	Catalogue musical	Aucune restriction

Classe	Exemples	Protection minimale
Interne	Métriques business, rapports	Employés authentifiés
Confidentielle	Historiques d'écoute, profils, segments	Chiffrement au repos et en transit, accès par rôle, pseudonymisation pour l'analytics
Sensible	Paielements, données inférées art. 9, mineurs	Chiffrement renforcé, accès nominatif minimal, journalisation obligatoire, DPIA

Accès et partage. L'accès se demande via le catalogue de données, il est accordé par le Data Steward du domaine selon la classe et le besoin (principe du moindre privilège), et il est revu trimestriellement. Le partage inter-départements se fait sur données **pseudonymisées ou agrégées par défaut** ; l'accès aux données identifiantes exige une finalité documentée. Aucun export de données confidentielles ou sensibles hors des plateformes gouvernées.

Cycle de vie (POSMAD : Plan, Obtain, Store & Share, Maintain, Apply, Dispose). Chaque dataset a une durée de conservation définie par son steward avec le DPO et inscrite au catalogue. Repères initiaux : logs d'écoute bruts identifiants 13 mois puis agrégation, données de compte pendant la relation contractuelle + délais légaux, données de paiement selon obligations comptables (sans stockage de numéro de carte chez Spotify), données marketing jusqu'au retrait du consentement. À échéance : suppression ou anonymisation irréversible.

Sécurité opérationnelle. Chiffrement systématique des classes Confidentielle et Sensible ; authentification forte ; journalisation centralisée dans le SIEM ; protocole d'incident piloté par le DPO (qualification sous 24 h, notification autorité sous 72 h, information des personnes si risque élevé) ; exercice annuel.

5. Conformité réglementaire

Bases légales par finalité (GDPR art. 6). Fourniture du service et facturation → **contrat** ; recommandation et personnalisation du service → **intérêt légitime ou contrat**, avec option de recommandation non fondée sur le profilage (DSA art. 27) ; publicité ciblée, partage à des tiers, features optionnelles → **consentement** explicite et révocable ; obligations comptables et fiscales → **obligation légale**. Chaque traitement est inscrit au registre des traitements (art. 30) tenu par le DPO.

Droits des personnes.

Droit	Base	Délai	Mise en œuvre
Accès et information (source, destinataires, durées, transferts)	GDPR art. 15, CCPA	1 mois / 45 j	Export libre-service complet ; Privacy Team pour le reste
Rectification	GDPR art. 16, CPRA	1 mois	Paramètres du compte
Effacement	GDPR art. 17, CCPA	1 mois	Pipeline automatisé sur tous les systèmes du domaine
Portabilité	GDPR art. 20	1 mois	Export JSON/CSV
Opposition et limitation	GDPR art. 18, 21	1 mois	Désactivation du profilage publicitaire, gel du traitement
Décision automatisée	GDPR art. 22, DSA art. 27	—	Explicabilité des recommandations, option non profilée
Opt-out de la vente / du partage	CCPA/CPRA	Immédiat	Lien « Do Not Sell or Share », signal GPC honoré
Non-discrimination	CCPA	—	Aucune dégradation de service après exercice d'un droit

Consentement et transparence. Consentement recueilli et tracé par la plateforme de gestion des consentements, granulaire par finalité, aussi simple à retirer qu'à donner. Mineurs : âge minimum par pays, consentement parental (GDPR art. 8), pas de publicité ciblée.

DPIA. Obligatoire avant tout nouveau traitement à risque élevé (nouveau profilage, nouvelle catégorie de données, nouveau transfert), validée par le DPO avant mise en production.

Transferts internationaux. Clauses contractuelles types, EU-US Data Privacy Framework pour les prestataires certifiés, règles d'entreprise contraignantes intra-groupe ; inventaire des transferts au registre.

PCI-DSS. Les données de carte sont traitées par un prestataire de paiement certifié PCI-DSS ; Spotify ne stocke aucun numéro de carte (tokenisation). Obligations conservées par Spotify sur les six exigences de la checklist : réseau et page de paiement sécurisés (SAQ-A annuel), protection des jetons et données de facturation, gestion des vulnérabilités (scans

trimestriels, correctifs), contrôle d'accès strict et MFA sur les consoles de paiement, surveillance et tests (SIEM, pentest annuel), politique de sécurité de l'information revue annuellement.

Réglementations locales. CCPA/CPRA (Californie), PDPA (Singapour), LGPD (Brésil, amende jusqu'à 2 % du CA local), DSA (transparence des systèmes de recommandation), AI Act (obligations de transparence pour les systèmes de recommandation). La veille est tenue par le DPO et Legal ; la checklist de conformité (annexe Excel) est mise à jour trimestriellement.

6. Rôles et responsabilités

Les rôles suivent le Data Governance Roles Template ; l'organigramme et les fiches détaillées sont en Partie 3.

- **Chief Data Officer** — porte la stratégie et cette politique, pilote le Centre of Excellence, arbitre les conflits inter-domaines.
- **Data Protection Officer** — indépendant, rattaché à la direction générale ; conformité GDPR/CCPA, DPIA, registre, contact des autorités, pilotage des incidents ; dirige la Privacy Team.
- **Data Governance Committee** (mensuel) — approuve les politiques et standards, traite les sujets inter-départements, suit les KPIs.
- **Data Stewards** (un par domaine) — qualité, classification, accès et conformité de leur domaine.
- **Parties prenantes** — Head of Engineering (implémentation technique des contrôles, sous l'autorité du CTO : la gouvernance définit et audite, l'engineering met en œuvre), Legal (validation juridique), Marketing Director et Product Managers (conformité et privacy by design de leurs périmètres).

RACI des activités clés (A = rend compte, R = réalise, C = consulté, I = informé) :

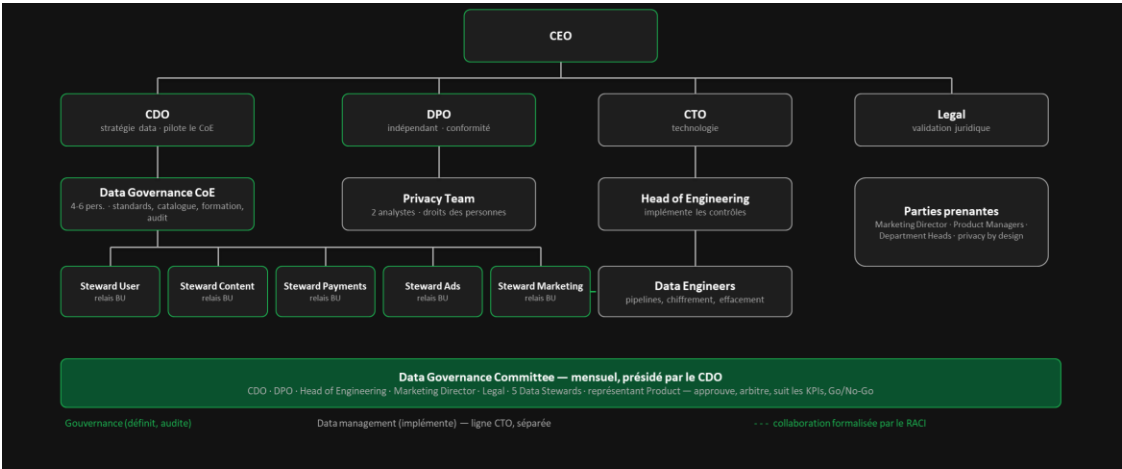
Activité	CDO	DPO	Head Eng.	Legal	Steward	Engineers	PM / Mktg
Définir et réviser la politique	A/R	C	C	C	C	I	C
Valider un nouveau traitement (DPIA)	I	A/R	C	C	R	I	R
Qualité et classification d'un domaine	I	C	C	I	A/R	R	C
Implémenter contrôles et pipelines	I	C	A/R	I	C	R	I
Traiter les demandes des personnes	I	A	C	C	R	R	I
Gérer un incident de données personnelles	C	A/R	R	C	C	R	I
Auditer les biais de recommandation	C	A	R	C	C	R	C
Former et animer la culture data	A/R	R	C	I	R	I	C

7. Application, exceptions et suivi

Le respect de cette politique est une obligation professionnelle ; les manquements sont traités selon les procédures RH et peuvent entraîner le retrait des accès. Toute exception est demandée par écrit au Data Steward, validée par le CDO (et le DPO si des données personnelles sont concernées), limitée dans le temps et consignée. Le CDO rend compte trimestriellement au comité exécutif des KPIs de gouvernance (qualité, délais de réponse aux droits, incidents, couverture du catalogue, formation). La politique est revue chaque année ; la version 1.0 est déployée d'abord sur le domaine User Data (voir plan d'implémentation).

Partie 3 — Organisation & rôles

Modèle **Centre of Excellence** : la gouvernance (CDO, CoE, Data Stewards) définit les standards et audite ; le data management (CTO, Head of Engineering, Data Engineers) implémente. Deux lignes hiérarchiques distinctes, une collaboration formalisée par le RACI (Partie 2, §6). Le DPO est hors de la ligne du CDO pour garantir son indépendance (GDPR art. 38).



Data Governance Committee — composition et ordre du jour type (mensuel, 60 min) : CDO (président), DPO, Head of Engineering, Marketing Director, Legal, 5 Data Stewards, 1 représentant Product. Ordre du jour : KPIs qualité par domaine · incidents et demandes des personnes · nouveaux traitements / DPIA · avancement du plan · audits de biais · décisions.

Rôle	Rattachement	Responsabilité principale	Tâches clés
Chief Data Officer	CEO	Diriger la stratégie et la gouvernance des données	Définir les politiques ; arbitrer les conflits inter-domaines ; piloter le CoE et le Committee ; aligner avec les priorités business ; rendre compte au comité exécutif
Data Protection Officer	CEO (indépendant)	Garantir la conformité GDPR, CCPA et réglementations locales	Registre des traitements ; DPIA ; contact des autorités ; pilotage des incidents et notification 72 h ; direction de la Privacy Team ; veille réglementaire avec Legal
Data Governance Committee	Présidé par le CDO	Guider le framework et assurer l'alignement transverse	Approuver politiques et standards ; traiter les sujets inter-départements ; suivre les KPIs ; valider les Go/No-Go du plan
Data Steward (x5 : User, Content, Payments, Ads, Marketing)	CoE + business unit	Superviser les pratiques data de son domaine	Qualité, classification et durées de conservation ; accorder et revoir les accès ; alimenter le catalogue ; faire appliquer la politique ; reporting mensuel

Parties prenantes (business case) :

Rôle	Contribution à la gouvernance
Head of Engineering (sous le CTO)	Implémentation technique : pipelines, chiffrement, SIEM, pipeline d'effacement, scalabilité
Legal Team	Validation juridique des politiques, contrats fournisseurs, litiges
Marketing Director	Conformité des campagnes (consentement, opt-out), qualité des données marketing
Product Managers	Privacy by design, DPIA sur chaque nouvelle feature, qualité des données produit
Privacy Team (DPO + 2 analystes)	Traitement des demandes des personnes dans les délais légaux (1 mois GDPR, 45 j CCPA)

Partie 4 — Implementation Plan & pilote

1. Modèle organisationnel : Centre of Excellence (CoE)

Modèle (Organizational Models Overview)	Avantages	Faillies	Verdict pour Spotify
Centralisé	Simple, priorisation claire	Les métiers ne s'approprient pas la donnée ; goulot d'étranglement	Non : 180+ pays, squads autonomes
Embedded	Agile, proche du métier	Pas de source unique de vérité, silos	Non : c'est le modèle de fait actuel, il produit les silos constatés
Centre of Excellence	Cumule les deux ; standards communs + relais dans chaque BU	Réservé aux grandes entreprises ; couche de coordination supplémentaire	Oui : Spotify est une grande entreprise ; la coordination est assurée par le Committee mensuel

Le CoE (4-6 personnes sous le CDO) porte les standards, le catalogue, la formation et l'audit ; les 5 Data Stewards sont les relais dans les business units. Conformément au cours, **gouvernance et data management sont séparés** : le CoE définit et audite, l'engineering (CTO) implémente.

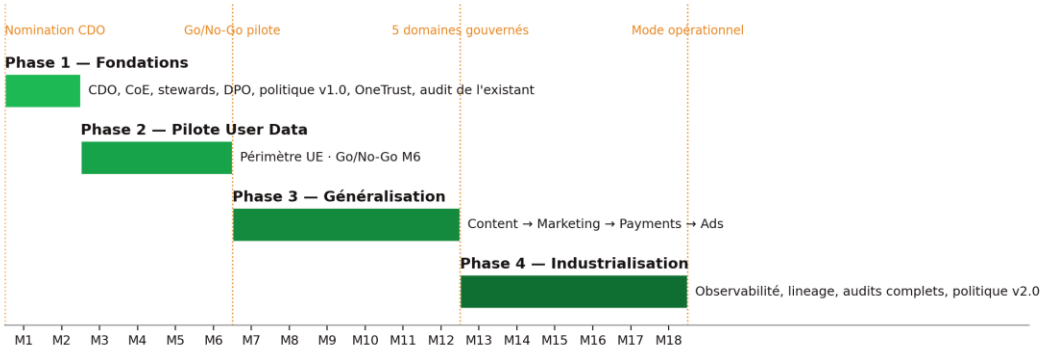
2. Stack technologique

Un outil par besoin, choisi dans le Tech Tools Overview selon trois critères : intégration avec l'existant GCP/Airflow, coût, couverture fonctionnelle. Spotify dispose déjà d'un catalogue interne (Lexikon) : la phase 1 audite l'existant avant tout achat.

Besoin	Outil retenu	Pourquoi	Alternative évaluée
Catalogue & stewardship	Collibra (ou extension de Lexikon)	Workflows de stewardship, glossaire, classification, intégration BigQuery	Alation, Apache Atlas
Qualité des données	Great Expectations	Open source, tests dans les pipelines Airflow existants, coût nul en licence	Talend
Conformité & consentement	OneTrust	Consentement multi-pays, registre, DPIA, gestion des demandes des personnes	TrustArc
Sécurité (SIEM)	Splunk	Journalisation centralisée, détection d'incidents	DataGuard
Chiffrement & clés	Vormetric (Thales CipherTrust)	Chiffrement des données sensibles au repos, gestion des clés	—
Lineage	OpenLineage + Marquez	Standard ouvert compatible Airflow, traçabilité de bout en bout	—
Observabilité (phase 4)	Monte Carlo	Détection d'anomalies et de fraîcheur	Ataccama ONE

3. Plan en 4 phases (18 mois)

Calendrier conforme à l'Executive Q&A Guide : pilote de 3 à 6 mois, puis 12 mois de déploiement.



Phase 1 — Fondations (M1-M2). Prérequis bloquant : nomination du CDO. Puis : constitution du CoE et désignation des 5 Data Stewards (fiches signées) ; confirmation du DPO et création de la Privacy Team ; approbation de la politique v1.0 par le Committee ; audit de l'existant (Lexikon, pipelines, consentement) ; déploiement OneTrust et instance pilote du catalogue ; cartographie des flux User Data ; communication de lancement (message CEO, webinar CDO, FAQ par rôle) et e-learning obligatoire. *Critère de sortie* : équipe en place, politique approuvée, baseline de mesure prête.

Phase 2 — Pilote User Data (M3-M6). Voir section 4. *Critère de sortie* : Go/No-Go du Committee sur les KPIs.

Phase 3 — Généralisation (M7-M12). Déploiement domaine par domaine, dans l'ordre de priorité du business case : **Content** (métadonnées, royalties), **Marketing** (consentement, métriques de conversion), **Payments** (PCI-DSS, chiffrement), **Ads** (opt-out CCPA/CPRA). Pour chaque domaine : cartographie → classification et durées de conservation → règles qualité dans les pipelines → DPIA si nécessaire → baseline puis cibles. Extension du pilote User Data des marchés UE au monde. *Critère de sortie* : 5 domaines catalogués et mesurés.

Phase 4 — Industrialisation (M13-M18). Observabilité (Monte Carlo), lineage de bout en bout, audit de conformité complet (GDPR/CCPA/PCI-DSS) et audit complet des biais de recommandation, formation avancée par rôle, tableau de bord exécutif, revue annuelle de la politique (v2.0). *Critère de sortie* : mode opérationnel continu, score de maturité ≥ 4,2.

4. Pilote User Data (Pilot Implementation Template)

Projet	Pilote du framework de Data Governance — domaine User Data
Période	M3 → M6 (4 mois)
Préparé par	Emeline ROBLOT, Data Governance Specialist
Project Manager	Lead du Data Governance CoE
Sponsor	CDO

Objectif et périmètre. Tester le framework complet (politique, rôles, outils, KPIs) sur le domaine le plus sensible et le plus créateur de valeur : les données utilisateurs. Périmètre borné pour être réaliste en 4 mois : **profils et historiques d'écoute des marchés UE** (juridiction la plus exigeante, sanction IMY 2023), extension mondiale en phase 3. Pourquoi User Data : exposition GDPR maximale, données pouvant révéler des informations sensibles inférées, impact direct sur Discover Weekly et la rétention premium.

Key goals (template). (1) Qualité : complétude et cohérence des données utilisateurs ; (2) Conformité GDPR/CCPA : droits des personnes et consentement ; (3) Accès et intégration : réduire les silos entre Product, Marketing et Engineering ; (4) Risque : classification, chiffrement, protocole d'incident testé.

Équipe.

Rôle	Responsabilités
Pilot Project Manager (Lead CoE)	Pilotage, coordination, reporting au Committee
Data Steward User	Qualité, classification, règles Great Expectations, catalogue
DPO + Privacy Team	Audit de conformité, DPIA, test du pipeline de droits
Data Engineers (Head of Engineering)	Intégration outils, pipeline d'effacement, pseudonymisation
Department Head (VP Product / User Experience)	Alignement métier, arbitrage des priorités, adoption

Jalons.

Jalon	Date	Responsable
Kick-off et mesure des baselines	M3 s1	Project Manager
Data assessment et cleansing (périmètre UE)	M3 s2 → M4 s2	Data Steward User
Audit de conformité GDPR/CCPA et DPIA	M4	DPO
Setup technique : catalogue, Great Expectations, pipeline d'effacement	M4 → M5 s2	Data Engineers
Revue à mi-parcours et ajustements	M5 s2	Project Manager
Premier audit des biais de recommandation	M5 s3-4	Head of Engineering + DPO
Revue finale, lessons learned, Go/No-Go	M6 s4	Project Manager → Committee

Livrables : Data Quality Report · Compliance Assessment · Technical Integration Plan · Risk Assessment Report · Stakeholder Feedback.

KPIs. Toutes les baselines sont mesurées en M3 semaine 1.

KPI	Définition	Baseline	Cible M6	Source
Data Quality Score	% de champs obligatoires manquants sur les datasets critiques User	à mesurer	-10 % de données manquantes (complétude > 98 %)	Great Expectations
Compliance Score	% de traitements User avec base légale documentée et consentement valide quand requis	à mesurer	100 %	OneTrust

KPI	Définition	Baseline	Cible M6	Source
Data Access Speed	Délai médian entre demande d'accès à un dataset et accès effectif	à mesurer	-20 %	Catalogue
Risk Mitigation Score	Datasets User classifiés et chiffrés selon leur classe ; incidents	à mesurer	100 % classifiés, 0 incident	Catalogue, Splunk
Droits des personnes	Délai de traitement d'une demande d'effacement / d'accès	à mesurer	< 30 jours , 100 % dans le délai légal	Privacy Team

Risques du pilote.

Risque	Prob.	Impact	Mitigation
Non-conformité résiduelle GDPR/CCPA	Moyenne	Élevé	Audit DPO en M4, formation, DPIA avant toute mise en production
Résistance au changement des squads	Élevée	Moyen	Ateliers dès M1, stewards issus des équipes, quick wins publiés
Qualité non améliorée	Faible	Élevé	Monitoring continu, revue à mi-parcours
Intégration technique (catalogue ↔ BigQuery, pipeline d'effacement)	Moyenne	Élevé	Engineering impliqué dès M1, POC en phase 1
Périmètre qui dérive	Moyenne	Moyen	Périmètre UE borné, changements validés par le Committee

Formation et conduite du changement. Ateliers pratiques pour les équipes User Data (catalogue, règles qualité, droits des personnes) ; documentation et helpdesk du CoE ; canal de feedback hebdomadaire → ajustements ; résultats du pilote publiés en interne comme quick wins.

Évaluation et lessons learned. Go/No-Go en M6 sur les KPIs ; rapport de retour d'expérience (ce qui a marché, blocages, temps réel vs estimé) ; feedback structuré des stakeholders ; ajustement de la politique et du plan de généralisation avant la phase 3.

5. Ressources et budget (ordres de grandeur, hypothèses à affiner en phase 1)

Poste	Hypothèse	18 mois
Personnel CoE (5 ETP) + Privacy Team (3 ETP) + 5 stewards à 50 % (2,5 ETP)	≈ 10,5 ETP × 120 k€ chargés / an	≈ 1,9 M€
Licences (catalogue, consentement, SIEM, chiffrement, observabilité)	1,5 à 2,5 M€ / an	≈ 3 M€
Intégration et conseil (setup, pipelines d'effacement, migration)	Forfait	0,5 à 1 M€
Formation et communication	E-learning, ateliers, supports	≈ 0,3 M€
Total programme		≈ 6 à 7 M€ sur 18 mois

À comparer à l'exposition maximale GDPR (4 % de 13,25 Md€ ≈ **530 M€**), à la sanction déjà subie en 2023 (≈ 5 M€) et au gain d'efficacité : à titre d'hypothèse, 500 analystes et data scientists gagnant 2 h par semaine de recherche de données représentent ≈ 50 000 h/an, soit ≈ 25 ETP (≈ 3 M€/an).

6. KPIs de suivi du programme

KPI	Cible	Owner
Complétude des datasets critiques (tous domaines)	> 98 % (mensuel)	Data Stewards
Demandes des personnes traitées dans le délai légal ; notification de violation	100 %, effacement < 30 j ; < 72 h	DPO / Privacy Team
Traitements avec base légale documentée	100 % (trimestriel)	DPO
Couverture du catalogue (classifié, owner, durée de conservation)	100 % des 5 domaines à M12	CoE
Délai d'accès aux données ; employés formés	-20 % vs baseline ; > 90 %	CoE
Incidents de données critiques ; audit des biais	0 ; trimestriel, 0 biais critique	Head of Engineering + DPO
Score de maturité	3,4 → 4,2 à M12 (semestriel)	CDO

Gouvernance du programme : le Data Governance Committee est le comité de pilotage (Go/No-Go de chaque phase) ; le CDO rend compte trimestriellement au comité exécutif. Dépendances : nomination du CDO (M1) → tout le reste ; approbation du budget phases 1-2 avant M1 ; disponibilité des Data Engineers dès M1.

Annexe A — Compliance Checklist (GDPR · CCPA/CPRA · PCI-DSS)

Checklist officielle du projet, complétée. Statut = état actuel estimé à l'issue du Data Maturity Assessment (hypothèse, sans accès aux données internes) ; action plan = mesures de la politique (Partie 2) ; échéance = mois du plan d'implémentation (Partie 4). Fichier de travail : 02-compliance-checklist.xlsx.

Exigence	Statut	Action plan	Owner	Échéance
GDPR - Data Processing Principles — Ensure data is processed lawfully, fairly, and transparently.	Partiel	Registre des traitements (art. 30) et base légale documentée par finalité (contrat / intérêt légitime / consentement / obligation légale). Data mapping OneTrust. Privacy notice réécrite par finalité, avec durées de conservation et transferts (point sanctionné par l'IMY en 2023).	DPO	M4
GDPR - User Rights — Users must be able to access, modify, or delete their data upon request.	Partiel	Couvrir les 7 droits (accès complet avec source/destinataires/durées/transferts, rectification, effacement, portabilité, opposition, limitation, décision automatisée). Pipeline d'effacement automatisé < 30 j sur tous les systèmes du domaine. Privacy Team (2 analystes) avec SLA 1 mois.	DPO + Privacy Team + Engineering	M6 (User Data), M12 (tous domaines)
GDPR - Consent Management — Obtain explicit, informed consent before processing personal data.	Partiel	Plateforme de gestion des consentements (OneTrust) granulaire par finalité, aussi simple à retirer qu'à donner. Consentement explicite pour publicité ciblée et partage à des tiers uniquement ; contrat / intérêt légitime pour le service. Consentement parental pour les mineurs (art. 8).	DPO + Product	M2 (déploiement), M6 (audit)
GDPR - Data Breach Notification — Notify supervisory authority of data breaches within 72 hours.	Partiel	Protocole d'incident : détection SIEM Splunk, qualification sous 24 h, notification autorité sous 72 h, information des personnes si risque élevé. Runbook + exercice annuel. Registre des violations.	DPO + Head of Engineering	M5 (runbook), M12 (exercice)
GDPR - Data Protection Officer — Appoint a Data Protection Officer for monitoring compliance.	Oui	DPO confirmé, rattaché à la direction générale hors ligne hiérarchique du CDO (indépendance, art. 38), enregistré auprès de l'autorité, dirige la Privacy Team, membre du Data Governance Committee.	CEO / Board	M1
CCPA - Data Sale Opt-out — Provide a clear opt-out mechanism for the sale of personal data.	Partiel	Lien « Do Not Sell or Share My Personal Information » visible (site et app), prise en compte du signal Global Privacy Control, opt-out propagé aux partenaires publicitaires sous 15 jours, suivi OneTrust.	Steward Ads + Product + Legal	M9 (domaine Ads)
CCPA - User Access and Deletion Requests — Allow users to request access to or deletion of their data.	Partiel	Portail libre-service (accès, suppression, correction CPRA) + traitement manuel par la Privacy Team, réponse < 45 jours, vérification d'identité, journal des demandes.	Privacy Team	M6
CCPA - Non-discrimination for Exercising Rights — Ensure no discrimination against users for exercising their CCPA rights.	Oui	Contrôle produit : aucune dégradation de service, de prix ou de qualité après exercice d'un droit ; test de non-régression à chaque release ; clause explicite dans la privacy notice.	Product Managers	M6 (vérification)
PCI-DSS - Secure Network and Systems — Ensure a secure network infrastructure and firewall protection.	Oui (périmètre délégué)	Paiements traités par un prestataire certifié PCI-DSS, aucun numéro de carte stocké chez Spotify (tokenisation). Périmètre résiduel : page de paiement et redirections sécurisées, segmentation réseau, questionnaire SAQ-A annuel.	Head of Engineering + Steward Payments	M10 (domaine Payments)
PCI-DSS - Protect Cardholder Data — Protect stored cardholder data using encryption and secure storage.	Oui (périmètre délégué)	Jetons et données de facturation classés « Sensible » : chiffrement au repos (Thales/Vormetric) et en transit, durées de conservation alignées sur les obligations comptables, suppression à échéance.	Steward Payments	M10
PCI-DSS - Maintain Vulnerability Management Program — Maintain systems for protection against malware and vulnerabilities.	Partiel	Scans de vulnérabilités trimestriels (ASV), patch management avec SLA, anti-malware sur les postes accédant aux consoles de paiement.	Head of Engineering	M10
PCI-DSS - Implement Strong Access Control Measures — Limit access to cardholder data to authorized personnel only.	Partiel	Accès aux consoles et données de paiement limité aux rôles nommés, MFA obligatoire, revue des accès trimestrielle, journalisation nominative.	Head of Engineering + Steward Payments	M10
PCI-DSS - Regularly Monitor and Test Networks — Implement systems to regularly test security measures and procedures.	Partiel	Journalisation centralisée dans Splunk, alertes sur accès anormaux, pentest annuel du parcours de paiement, revue des logs par le steward.	Head of Engineering	M10 (setup), annuel
PCI-DSS - Information Security	Partiel	Politique de sécurité de l'information annexée à la Data	CDO + DPO +	M2

Exigence	Statut	Action plan	Owner	Échéance
Policy — Maintain an updated information security policy for all personnel.		Governance Policy, communiquée à tout le personnel (e-learning obligatoire, > 90 % formés), revue annuelle.	Security	(publication), M12 (revue)

Annexe B — Sources et hypothèses

Chiffres sourcés (sources publiques, vérifiées en septembre 2026).

- **Sanction IMY** : autorité suédoise de protection des données, juin 2023 — amende administrative de 58 M SEK contre Spotify AB pour manquement au droit d'accès (GDPR art. 15 : information insuffisante sur les finalités, durées de conservation et transferts) ; confirmée par la cour administrative d'appel. Sources : imy.se, noyb.eu.
- **Chiffre d'affaires 2023** : 13,247 Md€ (Spotify Technology S.A., rapport annuel Form 20-F 2023) → 4 % ≈ 530 M€.
- **Catalogue interne Lexikon** et migration GCP/BigQuery depuis 2016 : Spotify Engineering, « How We Improved Data Discovery for Data Scientists at Spotify », février 2020 (adoption par 95 % des data scientists).
- **Contexte** : business case Jedha (450 M d'utilisateurs actifs, 200 M d'abonnés premium, 180+ pays, 2023).

Ressources Jedha utilisées. Data Maturity Assessment Template (9 dimensions) · Governance Principles Guide (9 principes) · Data Governance Roles Template (4 rôles) · Compliance Checklist (14 exigences, annexe A) · Organizational Models Overview (Centralisé / Embedded / CoE) · Tech Tools Overview · Pilot Implementation Template (10 sections) · Executive Q&A Guide (12 questions, traitées dans la présentation).

Hypothèses de travail (à valider en phase 1 — audit de l'existant). Existence d'un DPO en place ; délégation des paiements à un prestataire certifié PCI-DSS (aucun numéro de carte stocké) ; part de métadonnées de contenu incomplètes côté labels et distributeurs indépendants ; absence de SIEM unifié ; coûts du programme (10,5 ETP à 120 k€ chargés, licences 1,5-2,5 M€/an, intégration 0,5-1 M€, formation 0,3 M€) ; gain d'efficacité (500 analystes × 2 h/semaine) ; durées de conservation initiales. Chaque hypothèse est signalée « (hyp.) » à l'endroit où elle est utilisée.

Réglementations citées. GDPR (UE 2016/679) · CCPA (2018) et CPRA (2023) · PCI-DSS v4.0 · PDPA Singapour · LGPD Brésil · DSA (UE 2022/2065, art. 27 et 38) · AI Act (UE 2024/1689).